

Actividad 01: Análisis y Planificación del Pentest

Caso Práctico: Aurora Market ("Tu tienda, tu confianza, tu seguridad")

Nombre completo: Stephania Rivera Morales

Fecha de entrega: 4 de septiembre de 2026

Entorno de evaluación: Aurora Market - E-commerce Platform

Metodología de referencia: OWASP Web Security Testing Guide (WSTG v4.2) / PTES

1. Objetivo Concreto de la Evaluación de Seguridad (Explicación Amplia al Cliente)

El propósito fundamental de llevar a cabo una prueba de penetración técnica en la plataforma de e-commerce de Aurora Market trasciende la simple búsqueda de fallas menores o el cumplimiento de una verificación rutinaria. Esta propuesta responde directamente al reciente incidente de privacidad reportado por un usuario en relación con la consulta no autorizada de historial de pedidos y perfiles de cliente. Nuestra prioridad como equipo de pruebas de seguridad es proporcionar a la alta dirección y al equipo de TI una radiografía precisa, objetiva y basada en evidencias sobre el nivel real de exposición de sus activos informáticos.

Desde una perspectiva estratégica de negocio, realizar este pentest se justifica ampliamente por tres razones fundamentales:

- **Esclarecimiento y erradicación de la vulnerabilidad raíz (Fuga de Datos e IDOR):** Ante la sospecha de fallas de Control de Acceso Roto (específicamente Insecure Direct Object References - IDOR o Broken Object Level Authorization - BOLA), la prueba determinará con precisión matemática si un usuario autenticado o no autorizado puede manipular parámetros HTTP en URLs, campos de formularios o peticiones de API para acceder, modificar o exfiltrar información confidencial pertenecientes a otros clientes de la tienda.

- **Evaluación holística de la superficie de ataque y el postureo web:** La plataforma web de Aurora Market no opera de manera aislada; interactúa continuamente con paneles de administración interna, catálogos de productos, carritos de compra y pasarelas de pago. Por lo tanto, se auditarán exhaustivamente los vectores más críticos del OWASP Top 10, tales como inyecciones de código (SQLi, XSS), fallas de gestión de sesión, mecanismos de autenticación débiles y posibles desconfiguraciones en la infraestructura de los servidores de producción.

- **Protección reputacional, preservación de la confianza y cumplimiento regulatorio:** En una organización cuyo lema comercial es "Tu tienda, tu confianza, tu seguridad", la confianza depositada por los consumidores constituye el activo más valioso e insustituible. Identificar y remediar las brechas de seguridad de forma proactiva evita la exposición masiva de Información de Identificación Personal (PII), previene posibles sanciones regulatorias por incumplimiento normativo y blindo a la empresa contra pérdidas financieras directas derivadas de fraudes o ataques que comprometan la continuidad de sus operaciones.

2. Alcance Detallado de la Auditoría (Scope)

Para garantizar la efectividad de las pruebas y proteger los entornos no relacionados, se ha delimitado estrictamente el alcance de la siguiente manera:

A. Elementos Incluidos en la Evaluación (In-Scope)

- **Aplicación Web Principal (E-commerce):** Módulos públicos y autenticados: registro de usuario, inicio de sesión, recuperación de contraseña, catálogo de productos, procesamiento de carrito de compras, flujo lógico de la pasarela de pago y consulta de historial/estado de pedidos.
- **Panel Administrativo Interno:** Módulos de gestión de inventario, administración de perfiles de usuario, asignación de roles de empleados y gestión centralizada de pedidos de la tienda.
- **APIs y Endpoints HTTP/HTTPS:** Todos los servicios web RESTful o GraphQL expuestos que facilitan la comunicación de datos entre la interfaz web y la base de datos de usuarios y transacciones.

B. Elementos Excluidos de la Evaluación (Out-of-Scope)

- **Canales Externos y Redes Sociales:** Páginas oficiales de la empresa en redes sociales y plataformas de marketing externas.
- **Dispositivos de Empleados y Cuentas:** Equipos personales (endpoints), cuentas de correo corporativo y dispositivos móviles del personal de Aurora Market.
- **Infraestructura de Terceros:** Plataformas de procesamiento de pagos de terceros en sus propios dominios y servicios de infraestructura cloud fuera del control directo de la organización.
- **Ataques Disruptivos o Físicos:** Ataques de denegación de servicio (DoS/DDoS), pruebas de ingeniería social (Phishing, Spear Phishing) y pruebas de intrusión física a las instalaciones.

3. Autorización Legal y Reglas de Compromiso (Rules of Engagement)

Permisos e Requisitos Formales

- **Carta de Autorización Formal (RoE):** Documento legal firmado por la Gerencia General de Aurora Market que autoriza expresamente la ejecución de las pruebas técnicas en los entornos estipulados.
- **Acuerdo de Confidencialidad (NDA):** Garantía vinculante para proteger la privacidad de toda la información técnica, datos descubiertos y vulnerabilidades halladas durante la auditoría.
- **Cuentas de Prueba Proporcionadas:** Asignación de credenciales sintéticas de prueba con distintos niveles de privilegio (Rol Cliente A, Rol Cliente B y Rol Administrador) para auditar controles de acceso horizontal y vertical.

Condiciones de Operación y Salvaguardas

- **Ventana Horaria Restringida:** Las pruebas activas se ejecutarán exclusivamente fuera del horario pico transaccional.
- **Integridad de Datos en Producción:** Prohibición estricta de borrar, modificar o exfiltrar masivamente registros reales de clientes o compras de la base de datos.
- **Protocolo de Notificación Crítica:** Si se descubre una vulnerabilidad de impacto crítico que comprometa la estabilidad del servicio, las pruebas se pausarán inmediatamente para notificar al equipo técnico.

4. Selección del Tipo de Pentest y Justificación Técnica

TIPO SELECCIONADO: Gray-Box (Caja Gris)

JUSTIFICACIÓN TÉCNICA: Se selecciona la modalidad de Caja Gris debido a que Aurora Market otorgará información parcial sobre el entorno (arquitectura general del e-commerce, lista de endpoints principales de la API y credenciales de prueba para distintos roles de usuario) sin proporcionar acceso al código fuente ni a la administración del servidor subyacente. Esta perspectiva reproduce con la máxima fidelidad el escenario del incidente reportado: la posición de un atacante o usuario malintencionado que posee una cuenta legítima en la tienda o un conocimiento limitado del sistema, y que busca escalar privilegios o manipular la plataforma para consultar datos de terceros.

5. Estrategia Híbrida de Recopilación de Información

La recopilación de información se dividirá en un enfoque de dos fases integradas: reconocimiento pasivo (fuentes abiertas) y reconocimiento activo/autenticado (fuentes internas).

A. Reconocimiento Pasivo (Fuentes Abiertas - OSINT)

- **Descubrimiento de Subdominios y Rutas Expuestas:** Se emplearán técnicas avanzadas de búsqueda (Google Dorking) y herramientas especializadas como Sublist3r y Amass para identificar entornos de pruebas, subdominios olvidados, APIs secundarias o paneles de administración no enlazados públicamente.

- **Identificación de la Huella Tecnológica (Tech Stack):** Uso de Wappalyzer, BuiltWith y consultas pasivas HTTP para determinar el servidor web (Nginx, Apache), lenguajes y frameworks de desarrollo (Node.js, React, PHP), componentes del carrito de compra y versiones específicas de software en ejecución.

- **Revisión de Fuentes de Información Públicas:** Análisis de certificados SSL/TLS mediante Crt.sh, consulta de registros DNS públicos y revisión de repositorios abiertos para descartar la filtración accidental de credenciales, claves de API o endpoints internos.

B. Reconocimiento Activo e Interno (Fuentes Autenticadas)

- **Mapeo Sistemático de APIs y Rutas Internas:** Con las cuentas de prueba asignadas, se navegará por la plataforma interceptando el tráfico a través de un proxy para cartografiar cada endpoint de la API REST/GraphQL utilizada por la aplicación (/api/v1/orders/, /api/v1/users/profile, /admin/dashboard).

- **Construcción de Matriz de Autorización:** Comparación del comportamiento de las peticiones HTTP/HTTPS enviadas desde un usuario de tipo 'Cliente A' frente a un 'Cliente B' y un 'Administrador', identificando cómo viajan las cookies de sesión y tokens JWT.

6. Uso Práctico, Metodología y Propósito de Herramientas

A. Nmap (Network Mapper)

- **Práctica y Ejecución:** Lanzamiento de escaneos dirigidos y no invasivos sobre las direcciones IP y dominios comprendidos en el alcance mediante comandos de descubrimiento de puertos y servicios (ej. nmap -sV -sC -p 80,443,8080,8443 target).

- **Propósito Concreto:** Identificar con exactitud qué puertos y servicios web o de soporte están escuchando, determinar versiones exactas de servicios y detectar la presencia de servicios innecesarios o desactualizados expuestos a Internet.

B. Burp Suite Professional / Community (Proxy de Intercepción)

- **Práctica y Ejecución:** Constituye el pilar del análisis manual. Se configurará el navegador de pruebas para enrutar el tráfico HTTP/HTTPS a través del proxy, permitiendo capturar, analizar y modificar cada petición y respuesta.

- **Propósito Concreto:** Manipulación de parámetros en tiempo real para evaluar vulnerabilidades IDOR/BOLA (modificando identificadores en peticiones GET/POST como /api/user?id=101 a id=102), auditoría de la robustez de tokens de sesión y pruebas directas de inyección en el módulo Repeater.

C. OWASP ZAP (Zed Attack Proxy)

- **Práctica y Ejecución:** Ejecución de rastreos automatizados (Automated Spidering) y escaneos pasivos de vulnerabilidades sobre la arquitectura de la tienda.

- **Propósito Concreto:** Automatizar el descubrimiento de la estructura del sitio web para hallar endpoints no listados, detectar archivos olvidados (.env, robots.txt, copias de seguridad) y verificar la presencia de cabeceras de seguridad HTTP esenciales (CSP, X-Frame-Options, HSTS).

7. Propuesta de Ventana Horaria y Justificación Operativa

HORARIO PROPUESTO: Lunes a Viernes de 22:00 a 05:00 horas (Ventana Nocturna Off-Peak).

JUSTIFICACIÓN OPERATIVA DETALLADA:

- **Protección de la Experiencia del Cliente y Evitación de Carga:** Aurora Market es una tienda en línea con flujo de ventas activo durante el día. Ejecutar pruebas intensivas o de inyección durante horas pico de tráfico comercial podría saturar la base de datos, generar lentitud o causar caídas del servicio que afecten directamente las transacciones y ventas de la empresa.
- **Claridad en la Monitorización de Logs e Incidentes:** Durante la noche, el tráfico transaccional legítimo disminuye considerablemente. Esto facilita al equipo de infraestructura de Aurora Market distinguir entre el tráfico de uso habitual de la plataforma y el tráfico derivado de la prueba de penetración.
- **Margen Operativo de Respuesta Ante Imprevistos:** En caso de que una prueba genere una condición anómala no planificada en la base de datos o el servidor, la ventana nocturna proporciona un margen de tiempo suficiente para reiniciar servicios, restaurar estados o aplicar parches sin afectar la disponibilidad comercial diurna.

8. Reconocimiento Técnico y Descubrimiento de Puntos de Entrada

- **Escaneo de Puertos y Verificación de Servicios:** Uso de Nmap para confirmar que únicamente estén abiertos los puertos estipulados para servicios web seguros (443/HTTPS y 80/HTTP con redirección obligatoria), descartando la exposición indebida de servicios de administración remota o bases de datos (22/SSH, 3306/MySQL, 5432/PostgreSQL).
- **Descubrimiento de Rutas Ocultas (Directory Busting):** Ejecución de Gobuster o ffuf utilizando diccionarios especializados (SecLists) para identificar rutas no vinculadas en la interfaz pública, tales como /admin, /manage, /api/v1/docs, /swagger.json o archivos de configuración.
- **Análisis de Superficie e Inserción de Datos:** Mapeo metódico de todos los campos interactivos donde la aplicación reciba datos suministrados por el usuario: formularios de registro/login, barras de búsqueda, campos de perfil, cupones de descuento, parámetros URL (GET/POST) y cabeceras HTTP personalizadas.

9. Análisis y Priorización de Vulnerabilidades

HERRAMIENTAS CLAVE: Burp Suite (Repeater/Intruder) y OWASP ZAP.

IDENTIFICACIÓN PRIORITARIA Y OBJETIVOS:

- **Vulnerabilidades de Control de Acceso (IDOR / BOLA):** Comprobar de forma exhaustiva si un usuario autenticado con el rol 'Cliente A' puede acceder a las facturas, direcciones o historial de pedidos del 'Cliente B' modificando parámetros identificadores en las peticiones a la API.
- **Inyecciones de Código (SQLi, XSS):** Evaluar si las entradas en barras de búsqueda, filtros de productos o formularios interactúan de manera insegura con la base de datos SQL o si permiten la ejecución de scripts maliciosos en el navegador de otros usuarios.
- **Fallas de Autenticación y Gestión de Sesión:** Verificar la resistencia ante ataques de fuerza bruta, políticas de bloqueo de cuenta, expiración adecuada de cookies y transmisión segura de credenciales.
- **Desconfiguraciones en Servidores Web:** Identificar falta de parches de seguridad, uso de algoritmos criptográficos débiles o habilitación de métodos HTTP innecesarios (PUT, DELETE, TRACE).

USO DE RESULTADOS: Toda evidencia capturada (peticiones y respuestas HTTP) se documentará detalladamente para evaluar el nivel de riesgo según la escala internacional CVSS v3.1, sirviendo como insumo directo para la fase de explotación controlada y la redacción del informe.

10. Fases del Pentest Aplicadas al Escenario de Aurora Market

FLUJO METODOLÓGICO: [1. Reconocimiento] --> [2. Análisis Vulnerabilidades] --> [3. Explotación] --> [4. Post-Explotación] --> [5. Informe]

- **1. Reconocimiento (Mapeo de la Superficie):** Mapeo de la arquitectura de la tienda online mediante fuentes abiertas (OSINT) y escaneos de puertos (Nmap). Se obtendrán las tecnologías en uso, subdominios y endpoints de la API web sin interactuar agresivamente con los servicios.

- **2. Análisis de Vulnerabilidades (Identificación de Fallas):** Revisión minuciosa e inspección de los puntos de entrada mapeados utilizando Burp Suite y OWASP ZAP. Se buscarán patrones de fallas de Control de Acceso (IDOR), errores en tokens de sesión e inyecciones de datos, confirmando su presencia teórica sin alterar el estado del sistema.

- **3. Explotación Controlada (Verificación Práctica Segura):** Ejecución de Pruebas de Concepto (PoC) sintéticas sobre las vulnerabilidades identificadas. En el caso de IDOR, se demostrará técnicamente que el Cliente A puede visualizar una petición de pedido perteneciente al Cliente B, deteniendo la prueba de inmediato para no extraer masivamente ni comprometer datos reales.

- **4. Post-Explotación (Evaluación del Impacto Real en el Negocio):** Determinación del alcance potencial de las vulnerabilidades confirmadas: evaluar si la falla permite una escalada de privilegios (pasar de rol Cliente a Administrador) o si otorga acceso indebido a la estructura de la base de datos, midiendo el riesgo verdadero para las operaciones de Aurora Market.

- **5. Elaboración del Informe Técnico y Ejecutivo (Remediación):** Sintetización de los hallazgos en un documento final dividido en dos secciones: un Resumen Ejecutivo dirigido a la dirección de Aurora Market (con métricas de riesgo y prioridades de negocio) y un Informe Técnico detallado para el equipo de desarrollo, incluyendo evidencias de tráfico HTTP, clasificación CVSS v3.1 y recomendaciones concretas de parcheo.

11. Metodología de Evaluación Seleccionada

METODOLOGÍA DE REFERENCIA: OWASP WSTG (Web Security Testing Guide v4.2)

JUSTIFICACIÓN Y UTILIDAD PARA EL PROYECTO: OWASP WSTG v4.2 representa el estándar internacional por excelencia para la auditoría de aplicaciones web. Su adopción en este proyecto garantiza un marco metodológico riguroso y repetible para probar sistemáticamente los controles de autenticación, la gestión de sesiones y el control de acceso a datos. Esta metodología proporciona las pautas exactas para aislar y resolver el incidente de privacidad reportado en Aurora Market de manera estructurada y profesional.